

The mapping approach according to ANSSI

The morning arbitrated an inventory question: who takes the census, who answers for it, what to do with the discoveries. It also showed its limits: three subsidiaries, three replies, and no way to assemble them into a picture of the group. This lecture provides the method that turns scattered inventories into organized knowledge of the information system: mapping, as ANSSI has formalized it. By the end of the day, this method will no longer be an idea: it will be entered into the group's tool, subsidiary by subsidiary.

✓ A system one cannot see cannot be defended

Session objectives

By the end of this lecture:

- **Define** what an information system mapping is and situate it relative to the morning's inventory
- **State** the four stakes that justify the approach, and illustrate them on real cases and on the MERIDIAN group
- **Walk through** the five-step approach of the ANSSI guide, with its maturity trajectory and its granularities
- **Distinguish** the three visions and the six views, and state what each view reveals and whom it serves
- **Explain** to a management team why a mapping that does not live dies, with supporting examples

Prerequisites

- This morning's CISO briefing: the asset inventory, critical assets, shadow IT blind spots; mapping takes over exactly where the inventory stops.
- Session 1's framing: the MERIDIAN group's governance, its RACI matrix, the Group CISO's arbitrator role. None of that is redefined here; the map built in this session is an instrument in the service of that governance.

The context that makes the question urgent

3 586

SECURITY EVENTS HANDLED BY ANSSI IN 2025

ANSSI's Panorama de la cybermenace

66,7%

OF CESIN RESPONDENTS CITE IGNORANCE OF
THEIR ATTACK SURFACE AMONG THE TOP THREE
OBSTACLES TO MANAGING IT

CESIN, attack surface study, 2025

These two figures are read together: on one side a volume of security events counted in thousands per year for the national agency alone, on the other defenders who declare, two thirds of them, that they do not know the extent of what they defend. The industrialized threat strikes organizations fighting partly blind. The morning's briefing measured the same thing at MERIDIAN's scale: one man's memory at Logistique, a truncated export at Santé, serial discoveries at the Éducation & Territoires division. Today's question is therefore not "should we map?", it is: how to go from these fragments to a knowledge of the information system that genuinely serves deciding, protecting and reacting?

✓ What a mapping is, and why the inventory is only half of it

The French reference answer fits in one document: ANSSI's guide « Cartographie du système d'information » (information system mapping), Version 1.0, November 2018, ANSSI-PA-046. It is the source text of the entire session, and it teaches one to distrust everything said about it by people who have not read it.

First, the problem it solves. An inventory, even an excellent one, is a list: it says WHAT is owned. It does not say how these elements hold together, which flows connect them, which business activities collapse if one of them falls, nor where an attacker would pass from one to another. Yet all of a CISO's hard questions are questions of links: can this server be isolated without breaking payroll? Where can this compromise spread? The mapping is the answer to these questions: a representation of the information system and of its connections with the outside, built to show the links and no longer just the elements.

The guide says it with two verbs to remember in order: the mapping must make it possible to produce the asset inventory of the information system, the list of components and their detailed description, AND to present the system in the form of views, partial representations of the information system, its links and its workings. What this implies: the inventory is PART of the mapping, its first by-product, not a competitor nor an external prerequisite. One sometimes hears "a mapping is not an inventory", as if the guide opposed the two: it says exactly the opposite, and the morning's work is therefore already a piece of the map. What the mapping does not

do, on the other hand: it protects nothing by itself, no more than the inventory does. It makes the right decisions possible; they still have to be made.

The mapping

the full approach: who talks to whom, what depends on what

The inventory

the list of what I own

a by-product, not
the starting point

✓ The four stakes: what a map is for when all is well, and when all goes wrong

The guide justifies the approach with four stakes; here they are in its exact words, because they are the ones that one day get copied into an executive briefing.

The **control** of the information system, first: « disposer d'une vision commune et partagée du système d'information au sein de l'organisation » ("to have a common, shared vision of the information system within the organization"). The decisive word is "shared": this morning, knowledge of Logistique's information system existed, but in a single head. A vision that the IT department, the business lines and security do not share produces those meetings where everyone talks about a different system while believing they are talking about the same one.

The **protection**, next: « identifier les systèmes les plus critiques et les plus exposés, d'anticiper les chemins d'attaque possibles sur ces systèmes » ("to identify the most critical and most exposed systems, to anticipate the possible attack paths on these systems"). This is the direct extension of the morning's critical assets: the map adds to criticality the notion of exposure and, above all, that of path. A barely critical server connected to everything becomes, on the map, what it really is: a stepping stone.

The **defense**, the third stake: « réagir plus efficacement en cas d'incident ou d'attaque numérique, de qualifier les impacts et de prévoir les conséquences des actions défensives » ("to react more effectively in the event of a digital incident or attack, to qualify the impacts and to anticipate the consequences of defensive actions"). A real case shows what this means in a crisis room. During the sabotage of TV5 Monde, in 2015, a first in France according to ANSSI, the teams engaged in the response « ont mené en parallèle une activité de cartographie, pour mieux connaître le périmètre défendu, et des investigations » ("carried out, in parallel, a mapping activity, to gain better knowledge of the defended perimeter, and investigations"). That sentence from the activity report says the essential: in the middle of a crisis, part of the forces had to be diverted to draw the map that did not exist. Every hour spent mapping during the fire is an hour taken from extinguishing it; the map is drawn beforehand.

The **resilience**, finally: « identifier les activités clés de l'organisme afin de définir un plan de continuité d'activité » ("to identify the organization's key activities in order to define a business continuity plan"). The map connects machines to activities: it is what makes it possible to say which group activities survive the loss of a given data center, and hence to build a continuity that is not a wish.

Four stakes, four moments in a CISO's life: governing, preventing, reacting, surviving. The rest of the lecture, steps then views, is only the organization of the work that serves them.

✓ The five-step approach: a project to be steered, not a drawing to be ordered

The guide organizes the construction in five steps, which its table of contents phrases as questions. Here they are, in order and in its terms:

1. « Comment initier la démarche de cartographie ? » ("How do I initiate the mapping approach?")
2. « Quel modèle dois-je adopter ? » ("Which model should I adopt?")
3. « Quels outils dois-je utiliser ? » ("Which tools should I use?")
4. « Comment construire ma cartographie pas à pas ? » ("How do I build my mapping step by step?")
5. « Comment pérenniser ma cartographie ? » ("How do I sustain my mapping over time?")

Five questions, and already a lesson in method: the construction itself only comes fourth. The organizations that fail are almost always those that started by drawing.

Step 1, initiate. It is what separates a project from a quagmire. Initiating means delimiting the perimeter to be mapped, defining the target mapping and choosing the trajectory to reach it. The guide recommends a progressive trajectory, through « l'atteinte échelonnée de niveaux de maturité croissants » ("the staged attainment of increasing maturity levels"): one does not map everything, immediately, at the same level of detail. Three levels of granularity grade this detail, in the guide's exact terms, which will come back in the dossiers of a whole career:

granularité minimale de niveau 1 : informations indispensables ("minimal granularity, level 1: indispensable information")

granularité intermédiaire de niveau 2 : informations importantes ("intermediate granularity, level 2: important information")

granularité fine de niveau 3 : informations utiles ("fine granularity, level 3: useful information")

The wisdom of this division is budgetary as much as technical: aiming from the outset for fine granularity over the whole perimeter is scheduling the project's abandonment at the first difficult quarter. For MERIDIAN, the reasonable trajectory is obvious: a complete level 1 across the four subsidiaries before any finesse, then deepening where the stakes demand it, the Santé subsidiary and the inter-subsidiary thread first.

Steps 2 and 3, the model then the tools. The guardrail against two symmetrical drifts:

- mapping without a common nomenclature, and each subsidiary invents its own vocabulary;
- choosing the tool before knowing what will go into it, and the tool dictates the map.

The guide's order is an order of subordination: the model serves the perimeter, the tool serves the model. The afternoon brings this subordination to life: the group's tool is already chosen, but everything entered into it will have been defined BEFORE, by the method.

Step 4, build step by step. Two now-familiar moves: carrying out the information system inventory, then building the views, whose logic the next section details.

Step 5, sustain. The step everyone underestimates and that the guide treats with the most managerial seriousness: communicating about the mapping, and maintaining it. A map is a perishable product; the guide calls for reviews « de manière régulière et structurée » ("in a regular and structured manner"), carried by « un processus d'amélioration continue et une gouvernance bien définis » ("a continuous improvement process and well-defined governance"), without imposing a universal periodicity, and it specifies that the mapping must be « tenue à disposition du RSSI et du CERT de l'entité » ("kept available to the entity's RSSI and CERT").

What makes a map obsolete today is no longer just infrastructure projects: it is usage. According to IBM's 2025 Cost of a Data Breach report, among organizations with an AI governance policy, only 34 % regularly audit unapproved AI usage. In other words: even equipped with rules, two organizations out of three do not check what is growing in the shadow of their map. Sustaining is not an annual re-reading, it is a tooled vigilance over what appears, and the morning's eleven discoveries are its illustration at home.

Three visions, six views: the map is read in layers

It remains to know what a mapping concretely looks like. The guide answers with an architecture in three visions, moving progressively from business toward technology, each broken down into two views, partial representations of the information system. Six views in total, whose exact titles must be known, because every dossier of a career uses them as they are; the afternoon's tool, for its part, files its assets by class, and those classes fall under these views.

Vision	View (exact title from the guide)	What it shows	The MERIDIAN question it answers
Business	Vue de l'écosystème (ecosystem view)	The external entities the information system interacts with: partners, providers, authorities	Whom do we depend on, and who depends on us?
Business	Vue métier du système d'information (business view of the information system)	The activities and processes, placed back in their business environment	What does the group do, and with what information?
Application	Vue des applications (application view)	The software components, the services they offer, the data flows between them	Which applications carry patient management, freight, identities?
Application	Vue de l'administration (administration view)	The perimeters and privilege levels of users and administrators	Who can act on what, and with what rights?
Infrastructure	Vue des infrastructures logiques (logical infrastructure view)	Logical segmentation: IP address ranges, VLANs, filtering, routing	How are the networks separated, and where are the passages?
Infrastructure	Vue des infrastructures physiques (physical infrastructure view)	The hardware equipment and its location	Where physically are our machines, our rooms, our links?

Three remarks to turn this table into reflexes.

- **The progression from business toward technology is not decorative:** it says that the map STARTS with what the organization does, not with its servers, and that is what distinguishes it from the network diagram that measure 4 of the hygiene guide already requires of every organization.
- **Each view has its readers:** the ecosystem view speaks to the executive and the lawyer, the administration view to the auditor, the infrastructure views to operations teams; a map is not a single poster, it is a set of layers shown according to the audience.
- **The most neglected view is almost always the first.** The Viamedis and Almerys affair reminded everyone of this in 2024: two third-party payment operators hit in the same period, and a leak concerning in total more than 33 million people according to the CNIL; for the client organizations of these operators, the subject was precisely where few maps go, among the ecosystem's third parties.

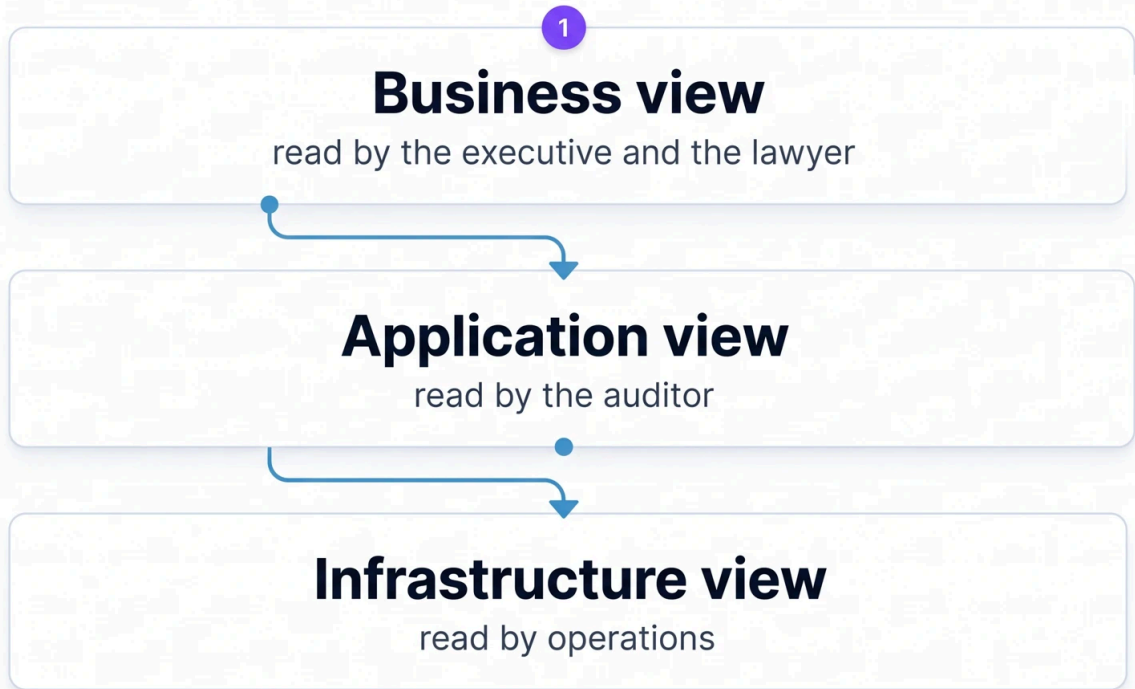
At MERIDIAN, the equivalent exists internally: Logistique's warehouse handheld scanners connected to Santé's inventory management system, with the segmentation the Group CISO imposed in session 1. This flow crosses the group's internal ecosystem view, the application view and the logical infrastructure view: one single business fact, three layers of map, and that is exactly why one does not draw everything on a single diagram.

To see the shape a view takes, an extract from outside the pack: the applications view of TRAMONTANE, the fictional online retailer of outdoor equipment that serves as the example outside the pack throughout the module, as its CISO drew it at the first maturity level. Three rows are enough to show what a view contains and what it does not.

Application	Service it provides	Inbound flows	Outbound flows	Owner
E-commerce site	Order taking, customer account	Customers' browsers	Orders to the ERP; payments to the payment service provider	Head of the web team
ERP	Sales management, stock, invoicing	Orders from the e-commerce site	Picking orders to the warehouse management system	IT department
Warehouse management system	Picking and shipping of orders	Orders from the ERP; reads from the picking terminals	Shipping notices to the carrier, by electronic data interchange	Warehouse manager (third-party publisher in remote maintenance)

Two lessons fit in these three rows. The flow to the payment service provider leaves the retailer's information system: it also belongs to the ecosystem view, where the provider appears as an external entity. And the remote maintenance by the warehouse system's publisher does not appear here: it lives in the administration view, with the privileges it carries. One business fact, several layers; the applications view says neither where the servers run nor who administers them, and that is how it stays readable.

From business to technology



✓ Equifax, 2017: the missing inventory worth 575 million dollars

A case study to anchor all of this, chosen because the American regulator documented its internal mechanics with rare precision. In 2017, the credit agency Equifax suffered a breach affecting about 147 million people, following, according to the FTC, a failure to secure its network.

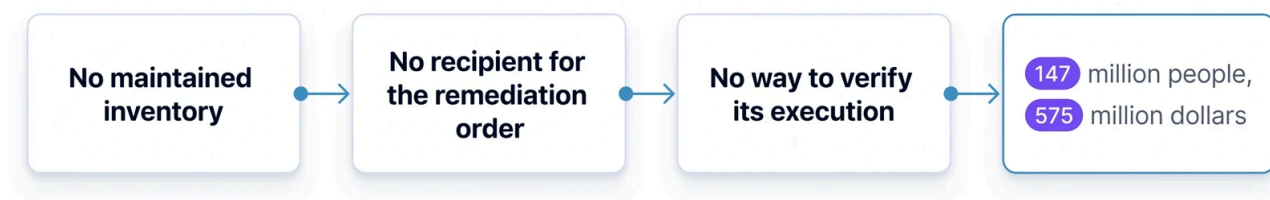
The detail that concerns this session lies elsewhere:

- alerted to a critical vulnerability, Equifax's security team had ORDERED the patching of all vulnerable systems within 48 hours;
- the FTC notes that the company never verified the execution of that order, for lack of asset tracking;
- the order was good, the policy existed, management had signed: what was missing was the map, the one that would have said which systems were vulnerable and who had to act on each;
- the settlement signed in 2019 with the FTC, the CFPB and the American states cost the company at least 575 million dollars.

ANSSI's hygiene guide, in its administrative coldness, asks for exactly what was missing there: the update policy must specify « la manière dont l'inventaire des composants du système d'information est réalisé » ("the manner in

which the inventory of the information system's components is carried out"). One sentence of a guide, half a billion dollars: it is the most spectacular conversion that can be cited between a line of method and an amount.

The lesson of Equifax is not "patches matter": that one belongs to another session. It lies in the causal chain proper to this session: without a tracked inventory, no identified recipients for the patching order; without a map, no possible verification of its execution. The mapping's function is not to look nice in committee: it is the infrastructure of decisions, including and above all urgent ones.



✓ What the map prepares: the afternoon, and the rest of the module

The road traveled, summarized: one definition, four stakes, five steps, six views. It remains to say what this map will be used for tomorrow, because a mapping is never an end. The guide phrases it in one sentence that bridges to the rest of the module: the mapping « facilite et accélère la conduite d'une appréciation de risques selon la méthode EBIOS Risk Manager » ("facilitates and accelerates the conduct of a risk assessment using the EBIOS Risk Manager method"). That risk assessment will come in due time, in sessions 5 and 7; no anticipating, except to note that nothing built today will have to be redone then.

The afternoon, for its part, is immediate and concrete. The first lab enters into the group's GRC tool the mapping of the subsidiary under study, from the subsidiary pack: the activities that matter, what they rest on, and the security needs attached to them, notions the upcoming tutorial first lays down with the precision of the official

vocabulary. The second draws from it the group's Top 5 critical assets and writes it into the strategy note opened in session 1. By the end of the day, each subsidiary's map will no longer be a project: it will exist, in a tool, and the group's Top 5 will be drawn from it, ready to serve as the foundation for everything this module builds next.